

觀察以企業角度 如何公私情資交流

情資交流的本質，不是誰擁有最多資訊，而是誰能讓資訊最快變成共同防禦



情資交流不是資料交換，而是防禦協作

1 為什麼

企業為什麼需要 公私情資交流

攻擊鎖定的是整個產業鏈、供應鏈與特定族群，而非單一企業。

2 如何接收

如何把外部情資 變成內部防禦

讓情報進入 SOC、EDR、SIEM、弱點管理與事件應變流程。

3 如何輸出

如何安全有效地 回饋情資給生態

在不暴露客戶與機敏資訊的前提下，提供他人可用的內容。

攻擊者看的是生態系，不是單一公司



供應鏈攻擊與委外風險增加，攻擊面延伸到合作夥伴



同一套攻擊手法可跨產業複用，今天金融、明天製造



釣魚、弱密碼、漏洞利用、外洩憑證反覆出現



單一企業只看內部事件，難以掌握完整攻擊樣貌



企業需要外部觀察，補足自身的內部盲點

不是沒有情資，而是不知道怎麼用



情資來源太多

品質參差不一，難以一致信任



IOC 過期或誤報

生命週期短、誤報率高



缺少情境

難以判斷處理的優先順序



未對應內部資產

不知道是否影響自己的環境



缺派工與追蹤

沒有明確的處理流程



看完沒有後續

情資停在信箱，沒有行動

情資交流不是雙邊，而是生態系



社群提供速度、深度與擴散能力



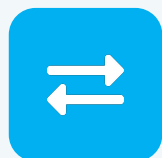
第一線技術觀察



快速 PoC 與手法驗證



開源工具與偵測規則



跨產業、跨組織經驗交換



事件中即時討論與補充線索



對企業與公部門的技術回饋

從 IOC 到 TTP, 再到決策情報



企業不只問「有哪些 IOC」, 更要問「這代表什麼風險」「我們該做什麼」。

生命週期

策略層 ↑ 長期價值

某波攻擊是否針對特定產業？是否與供應鏈有關？是否需調整投資優先順序？

戰術層 (TTP)

攻擊者如何取得初始存取、橫向移動、繞過偵測、竊取資料，這才是長期價值。

技術層 (IOC) ↓ 短命

IP、Domain、Hash 很重要，但生命週期短，攻擊者可快速更換。

接收情資後，要能進入 內部流程



1

分類

這是哪一類情資？

漏洞 · 惡意 IP · 攻擊活動 ·
釣魚 · 政策提醒

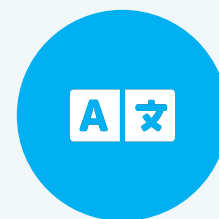


2

驗證

是否與企業有關？

是否使用受影響 產品？來
源可信度如何？



3

轉譯

要變成什麼防禦動作？

新增規則 · 封鎖 · 盤點 · 修
補 · 威脅狩獵



4

追蹤

是否完成處置與回饋？

誰處理、處理到哪、結果如
何、是否回報

讓情資進入 SOC、IT、風險與管理流程



SOC

偵測、監控、威脅狩獵



IT / MIS

修補、設定調整、帳號檢查



事件應變

確認是否受害、保全證據



風險管理

影響評估、決定優先順序



管理層

資源配置與資安決策

善用社群，但不要盲信社群

社群情資要快，也要可驗證—使用前先過五道關。

1 來源可信度

2 技術內容是否可驗證

3 是否與自身資產相關

4 是否可能造成誤判或過度封鎖

5 是否能轉成內部偵測與處置

不是所有情資都要立刻處理

優先順序判斷依據



是否與企業資產相關



是否正在被積極利用



是否影響關鍵系統 (AD/VPN/郵件)



是否有外部暴露面



是否涉及高價值資料



情資來源可信度

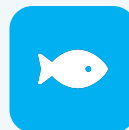


是否有社群/同業交叉驗證

分享不是公開所有細節，而是提供可行動資訊



攻擊手法



釣魚信樣態



惡意基礎設施



被利用漏洞



偵測邏輯



防禦建議



去識別化後的事件觀察

重點不是講出「誰被打」，而是讓其他人知道「怎麼防」。

從情資消費者，變成情資貢獻者



分享去識別化攻擊觀察



貢獻偵測規則
(Sigma/YARA)



回報惡意基礎設施



分享防禦經驗



參與研討會、社群與
工作小組



支持開源資安工具與
研究

分享前的三個檢查：可分享、可理解、可使用

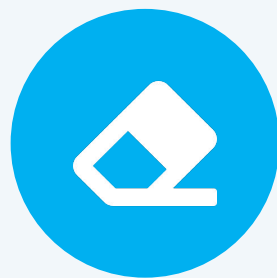
1



去識別化

移除公司名稱、個資、客戶資訊、內部 IP、主機名稱與帳號資訊。

2



移除機敏資訊

內部架構、事件處理細節、尚未修補的弱點、法務敏感內容。

3



提供足夠上下文

補上攻擊階段、關聯手法與偵測建議，只丟一個 IP 幫助有限。

社群情資快，但企業需要治理

社群價值

- ✓ 速度快
- ✓ 技術細節多
- ✓ 開源工具多
- ✓ 經驗分享真實
- ✓ 可促成跨界合作

企業要注意

- ！ 可能未完整驗證
- ！ 可能缺少企業情境
- ！ 需要安全測試
- ！ 可能涉及敏感資訊
- ！ 需要建立信任與規範

不分享，通常不是不願意，而是不知道怎麼安全分享



法務與合規疑慮



商譽與客戶信任考量



缺乏分享格式



不知道分享給誰



缺乏信任圈



沒有內部授權流程



擔心社群討論失控或被誤解

情資交流不能只靠熱情，也需要制度。

情資交流需要治理，不只需要工具



情資來源清單



情資分級標準



處理 SLA



分享授權流程



去識別化規範



社群互動準則



回饋與成效衡量

成效要可衡量：是否降低偵測時間？加速修補？避免事件擴大？

工具只是輔助，流程才是關鍵



TIP 情資平台



SIEM 關聯分析與告警



SOAR 自動化處置



EDR / NDR 端點與網路偵測



Ticket 派工與追蹤



CMDB / ASM 資產關聯

沒有流程，TIP 只是另一個資料庫，SIEM 只是更多告警，SOAR 可能自動化了錯誤的事。

情資交流成熟度模型：從被動接收到主動協作



大多數企業不需要一開始就做到 Level 5，但至少要知道下一步往哪裡走。

重大漏洞情資：從漏洞通報到企業處置

1

盤點是否使用受影響 產品

2

確認是否有外部暴露

3

檢查是否已有攻擊跡象

4

參考公部門、供應商與社群驗證

5

制定修補或緩解計畫

6

回報處理狀態(對 內 + 對外)

針對產業的釣魚攻擊：一封信可能是整個產業的預警

可分享的内容(去識別化後)



郵件主旨與寄件特徵



假冒品牌或單位



惡意連結或附件特徵



社交工程話術



偵測與阻擋方式



去識別化後的樣本特徵

企業參與社群，不只是派人聽演講



鼓勵資安人員參與社群活動



讓內部研究在安全範圍內對外分享



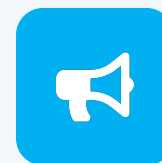
贊助或支持在地資安社群



參與 CTF、研討會、技術小聚



與學界、研究人員建立合作



建立企業對外技術發聲窗口

企業可以立即做的五件事

1 建立情資接收窗口

不要讓情資散落在不同信箱或個人通訊軟體

2 定義情資分級與處理流程

哪些緊急、哪些觀察、哪些只是參考

3 建立內部派工與追蹤機制

確保情資有人處理、有結果、有回饋

4 制定對外分享與社群互動規範

什麼可分享、誰能代表公司、何時需核准

5 加入可信任的產業或社群管道

信任的圈子，比公開大量資訊更有價值

讓資訊最快變成共同防禦

-  情資不是收藏品，而是行動觸發器
-  分享不是揭露弱點，而是建立共同防禦
-  公部門提供框架、企業提供現場、社群提供速度與深度
-  企業應從接收者，逐步成為貢獻者

當企業、公部門與社群能互相信任、互相補位，情資交流就不只是通報，而會成為真正的防禦力量。

凝聚台灣數位防線，連結世界資安生態

 service@twcsa.org

 台灣數位安全聯盟

 vLAB Online - ICT SecOps

 台灣數位安全聯盟

 vLAB Online 台灣路由網路實驗中心